(A) be reasonably designed to (1) ensure the confidentiality of [the]CAT Data[obtained from the Central Repository]; and (2) limit the use of CAT Data to [obtained from the Central Repository] solely [for]surveillance and regulatory purposes[.]; [Each Participant shall periodically review the effectiveness of the policies and procedures required by this paragraph, and take prompt action to remedy deficiencies in such policies and procedures.]

(B) limit extraction of CAT Data to the minimum amount of data necessary to achieve a specific surveillance or regulatory purpose;

(C) limit access to CAT Data to persons designated by Participants, who must be (1) Regulatory Staff or (2) technology and operations staff that require access solely to facilitate access to and usage of the CAT Data by Regulatory Staff;

(D) implement effective information barriers between such Participants' Regulatory Staff and non-Regulatory Staff with regard to access and use of CAT Data;

(E) limit access to CAT Data by non-Regulatory Staff, by allowing such access only where there is a specific regulatory need for such access and requiring that a Participant's Chief Regulatory Officer (or similarly designated head(s) of regulation), or his or her designee, document his or her written approval of each instance of access by non-Regulatory Staff;

(F) require all Participant staff who are provided access to CAT Data to: (1) sign a "Safeguard of Information" affidavit as approved by the Operating Committee pursuant to Section 6.5(f)(i)(B); and (2) participate in the training program developed by the Plan Processor that addresses the security and confidentiality of information accessible in the CAT pursuant to Section 6.1(m), provided that Participant staff may be provided access to CAT Data prior to meeting these requirements in exigent circumstances;

(G) define the individual roles and regulatory activities of specific users;

(H) impose penalties for staff non-compliance with the Participant's or the Plan Processor's policies, procedures, or usage restriction controls with respect to information security, including, the policies required by Section 6.5(g)(i);

(I) be reasonably designed to implement and satisfy the Customer and Account Attributes data requirements of Section 4.1.6 of Appendix D such that Participants must be able to demonstrate that a Participant's ongoing use of Programmatic CAIS and/or CCID Subsystem access is in accordance with the Customer Identifying Systems Workflow; and

(J) document monitoring and testing protocols that will be used to assess Participant compliance with the policies.

(ii) The Participants shall periodically review the effectiveness of the policies and procedures and usage restriction controls required by Section 6.5(g)(i), including by using the monitoring and testing protocols documented within the policies pursuant to Section 6.5(g)(i)(J), and take prompt action to remedy deficiencies in such policies, procedures and usage restriction controls.

(iii) Each Participant shall as promptly as reasonably practicable, and in any event within 24 hours of becoming aware, report to the Chief Compliance Officer, in accordance with the guidance provided by the Operating Committee: (A) any instance of noncompliance with the policies, procedures, and usage restriction controls adopted by such Participant pursuant to Section 6.5(g)(i); or (B) a breach of the security of the CAT.

(iv) The Participants shall make the policies required by Section 6.5(g)(i) publicly available on each of the Participant websites, or collectively on the CAT NMS Plan website, redacted of sensitive proprietary information.

(v) On an annual basis, each Participant shall engage an independent accountant to perform an examination of compliance with the policies required by Section 6.5(g)(i) in accordance with attestation standards of the AICPA (referred to as U.S. Generally Accepted Auditing Standards or GAAS) or the PCAOB, and with Commission independence standards based on SEC Rule 2-01 of Regulation S-X. The independent accountant's examination report shall be submitted to the Commission upon completion, in a text-searchable format (e.g. a text-searchable PDF). The examination report provided for in this paragraph shall be considered submitted with the Commission when electronically received by an email address provided by Commission staff.

(vi) The policies required by Section 6.5(g)(i) are subject to review and approval by the Operating Committee, after such policies are reviewed by the Chief Compliance Officer and Chief Information Security Officer pursuant to Sections 6.2(a)(v)(R) and 6.2(b)(viii).

* * * * *

Section 6.6 [Regular] Written Assessments, Audits and Reports.

* * * * *

(b) Regular Written Assessment of the Plan Processor's Performance.

* * * * *

(ii) Contents of Written Assessment. The annual written assessment required by this Section 6.6 shall include:

* * * * *

(B) a detailed plan, based on the evaluation conducted pursuant to Section 6.6(b)(i), for any potential improvements to the performance of the CAT with respect to the items specified in SEC Rule 613(b)(6)(ii), as well as:

* * * * *

(3) an evaluation of the Comprehensive I[i[nformation S[s]ecurity P[p]rogram to ensure that the program is consistent with the highest industry standards for the protection of data[;], as part of which, the CCO, in collaboration with the CISO, shall review the quantity and type of CAT Data extracted from the CAT System to assess the security risk of permitting such CAT Data to be extracted and identify any appropriate corrective measures;

* * * * *

Section 6.10 Surveillance

* * * * *

(c) Use of CAT Data by Regulators.

* * * * *

(ii) Extraction of CAT Data shall be consistent with all permission rights granted by the Plan Processor. All CAT Data returned shall be encrypted, and [PII] Customer and Account Attributes data shall be [masked]unavailable unless users have permission to view the CAT Data that has been requested.

* * * * *

Section 6.12. Comprehensive Information Security Program. The Plan Processor shall develop and maintain the C[c]omprehensive I[i]nformation S[s]ecurity P[p]rogram [for the Central Repository], to be approved and reviewed at least annually by the Operating Committee, and which contains at a minimum the specific requirements detailed in Appendix D, Data Security and Section 6.13.

* * * * *

Section 6.13. Secure Analytical Environments.

(a) SAW Environments. The Comprehensive Information Security Program shall apply to every Participant's SAW and must, at a minimum:

(i) Establish data access and extraction policies and procedures that include the following requirements:

(A) Participants shall use SAWs as the only means of accessing and analyzing Customer and Account Attributes.

(B) Participants shall use SAWs when accessing and analyzing CAT Data through the user-defined direct query and bulk extract tools described in Section 6.10(c)(i)(B) and Appendix D, Section 8.2, unless receiving an exception as set forth in Section 6.13(d).

(C) Participants shall only extract from SAWs the minimum amount of CAT Data necessary to achieve a specific surveillance or regulatory purpose.

(D) Secure file sharing capability provided by the Plan Processor shall be the only mechanism for extracting CAT Data from SAWs.

(ii) Establish security controls, policies, and procedures for SAWs that require all NIST SP 800-53 security controls and associated policies and procedures required by the Comprehensive Information Security Program to apply to the SAWs, provided that:

(A) For the following NIST SP 800-53 control families, at a minimum, security controls, policies, and procedures, shall be applied by the Plan Processor and shall be common to both the SAWs and the Central Repository in accordance with Section 2.4 of NIST SP 800-53, unless technologically or organizationally not possible: audit and accountability, security assessment and authorization, configuration management, incident response, system and communications protection, and system and information integrity; and

(B) SAW-specific security controls, policies, and procedures shall be implemented to cover any remaining NIST SP 800-53 security controls for which common security controls, policies, and procedures are not possible.

(b) Detailed Design Specifications.

(i) The Plan Processor shall develop, maintain, and make available to the Participants detailed design specifications for the technical implementation of the access, monitoring, and other controls required for SAWs by the Comprehensive Information Security Program controls.

(ii) The Plan Processor shall notify the Operating Committee that each Participant's SAW has achieved compliance with the detailed design specifications before that SAW may connect to the Central Repository.

(c) SAW Operations.

(i) In accordance with the detailed design specifications developed pursuant to Section 6.13(b)(i), the Plan Processor shall monitor each Participant's SAW, for compliance with the Comprehensive Information Security Program and the detailed design specifications

developed pursuant to Section 6.13(b)(i) only, and notify the Participant of any identified non-compliance with the Comprehensive Information Security Program or with the detailed design specifications developed pursuant to Section 6.13(b)(i).

(ii) Participants shall comply with the Comprehensive Information Security Program, comply with the detailed design specifications developed pursuant to Section 6.13(b)(i), and promptly remediate any identified non-compliance.

(iii) Each Participant may provide and use its choice of software, hardware configurations, and additional data within its SAW, so long as such activities comply with the Comprehensive Information Security Program.

(d) Non-SAW Environments.

(i) A Participant may seek an exception from the requirements of Section 6.13(a)(i)(B). If such exception is granted, the Participant may employ the user-defined direct query or bulk extract tools described in Section 6.10(c)(i)(B) and Appendix D, Section 8.2 in a non-SAW environment.

(A) To seek an exception from Section 6.13(a)(i)(B), the requesting Participant shall provide the Chief Information Security Officer, the Chief Compliance Officer, the members of the Security Working Group (and their designees), and Commission observers of the Security Working Group with:

(1) A security assessment of the non-SAW environment, conducted within the last twelve (12) months by a named, independent third party security assessor, that: (a) demonstrates the extent to which the non-SAW environment complies with the NIST SP 800-53 security controls and associated policies and procedures required by the Comprehensive Information Security Program pursuant to Section 6.13(a)(ii), (b) explains whether and how the Participant's security and privacy controls mitigate the risks associated with extracting CAT Data to the non-SAW environment through user-defined direct query or bulk extract tools described in Section 6.10(c)(i)(B) and Appendix D, Section 8.2, and (c) includes a Plan of Action and Milestones document detailing the status and schedule of any corrective actions recommended by the assessment; and

(2) Detailed design specifications for the non-SAW environment demonstrating: (a) the extent to which the non-SAW environment's design specifications adhere to the design specifications developed by the Plan Processor for SAWs pursuant to Section 6.13(b)(i), and (b) that the design specifications will enable the operational requirements set forth for non-SAW environments in Section 6.13(d)(iii).

(B) Within 60 days of receipt of the materials described in Section 6.13(d)(i)(A), the Chief Information Security Officer and the Chief Compliance Officer must simultaneously notify the Operating Committee and the requesting Participant of their determination.

(1) The Chief Information Security Officer and the Chief Compliance Officer may jointly grant an exception if they determine, in accordance with policies and procedures developed by the Plan Processor, that the residual risks identified in the security assessment or detailed design specifications provided pursuant to Section 6.13(d)(i)(A) do not exceed the risk tolerance levels set forth in the risk management strategy developed by the Plan Processor for the CAT System pursuant to NIST SP 800-53. If an exception is granted, the Chief Information Security Officer and the Chief Compliance Officer shall provide the requesting Participant with a detailed written explanation setting forth the reasons for that determination.

(2) If the Chief Information Security Officer and the Chief Compliance Officer decide not to grant an exception to the requesting Participant, they must provide the Participant with a detailed written explanation setting forth the reasons for that determination and specifically identifying the deficiencies that must be remedied before an exception could be granted.

(C) If a request for an exception from Section 6.13(a)(i)(B) is denied, the requesting Participant may attempt to re-apply, after remedying the deficiencies identified by the Chief Information Security Officer and the Chief Compliance Officer, by submitting a new security assessment that complies with the requirements of Section 6.13(d)(i)(A)(1) and up-to-date versions of the materials specified in Section 6.13(d)(i)(A)(2).

(ii) Continuance of any exception granted pursuant to Section 6.13(d)(i) is dependent upon an annual review process.

(A) To continue an exception, the requesting Participant shall provide a new security assessment that complies with the requirements of Section 6.13(d)(i)(A)(1) and up-to-date versions of the materials required by Section 6.13(d)(i)(A)(2) to the Chief Information Security Officer, the Chief Compliance Officer, the members of the Security Working Group (and their designees), and Commission observers of the Security Working Group at least once a year, as measured from the date that the initial application materials were submitted. If these materials are not provided by the specified date, the Chief Information Security Officer and the Chief Compliance Officer must revoke the exception in accordance with remediation timelines developed by the Plan Processor.

(B) Within 60 days of receipt of the updated application materials, the Chief Information Security Officer and the Chief Compliance Officer must simultaneously notify the Operating Committee and the requesting Participant of their determination.

(1) The Chief Information Security Officer and the Chief Compliance Officer may jointly continue an exception if they determine, in accordance with policies and procedures developed by the Plan Processor, that the residual risks identified in the security assessment or detailed design specifications provided pursuant to Section 6.13(d)(ii)(A) do not exceed the risk tolerance levels set forth in the risk management strategy developed by the Plan Processor for the CAT System pursuant to NIST SP 800-53. If the exception is continued, the Chief Information Security Officer and the Chief Compliance Officer shall provide the requesting Participant with a detailed written explanation setting forth the reasons for that determination.

(2) If the Chief Information Security Officer and the Chief Compliance Officer decide not to continue an exception, they must provide the requesting Participant with a detailed written explanation setting forth the reasons for that determination and specifically identifying the deficiencies that must be remedied before an exception could be granted anew.

(C) If a request for a renewed exception from Section 6.13(a)(i)(B) is denied, or if an exception is revoked pursuant to Section 6.13(d)(ii)(A), the CISO and the CCO must require the requesting Participant to cease employing the user-defined direct query or bulk extract tools described in Section 6.10(c)(i)(B) and Appendix D, Section 8.2 in its non-SAW environment in accordance with the remediation timeframes developed by the Plan Processor. The requesting Participant may attempt to re-apply for an exception, after remedying the deficiencies identified by the Chief Information Security Officer and the Chief Compliance Officer, by submitting a new security assessment that complies with the requirements of Section 6.13(d)(i)(A)(1) and up-to-date versions of the materials specified in Section 6.13(d)(i)(A)(2).

(iii) Non-SAW Operations. During the term of any exception granted by the Chief Information Security Officer and the Chief Compliance Officer:

(A) The Participant shall not employ the non-SAW environment to access CAT Data through the user-defined direct query or bulk extract tools described in Section 6.10(c)(i)(B) and Appendix D, Section 8.2 until the Plan Processor notifies the Operating Committee that the non-SAW environment has achieved compliance with the detailed design specifications provided by the Participant pursuant to Section 6.13(d)(i) or (ii).

(B) The Plan Processor shall monitor the non-SAW environment in accordance with the detailed design specifications provided by the Participant pursuant to Section 6.13(d)(i) or (ii), for compliance with those detailed design specifications only, and shall notify the Participant of any identified non-compliance with these detailed design specifications. The Participant shall comply with such detailed design specifications and promptly remediate any identified non-compliance.

(C) The Participant shall simultaneously notify the Plan Processor, the members of the Security Working Group (and their designees), and Commission observers of the Security Working Group of any material changes to its security controls for the non-SAW environment.

(D) The Participant may provide and use its choice of software, hardware, and additional data within the non-SAW environment, so long as such activities comply with the detailed design specifications provided by the Participant pursuant to Section 6.13(d)(i) or (ii).

* * * * *

APPENDIX C

Appendix C was filed with the CAT NMS Plan that was published for comment on May 17, 2016.[803] As required by Rule 613, Appendix C includes discussion of various considerations related to how the Participants propose to implement the requirements of the CAT NMS Plan, cost estimates for the proposed solution, and the costs and benefits of alternate solutions considered but not proposed. Because these discussions were intended to ensure that the Commission and the Participants had sufficiently detailed information to carefully consider all aspects of the national market system plan that would ultimately be submitted by the Participants, these discussions have not been updated to reflect the subsequent amendments to the CAT NMS Plan and Appendix D.

DISCUSSION OF CONSIDERATIONS

SEC RULE 613(a)(1) CONSIDERATIONS

* * * * *

Appendix D

* * * * *

[803] See Securities Exchange Act Release No. 77724 (April 27, 2016), 81 FR 30613.

4.1 Overview

* * * * *

The Plan Processor must provide to the Operating Committee a C[c]omprehensive Information S[s]ecurity P[p]lan that covers all components of the CAT System, including physical assets and personnel, and the training of all persons who have access to the Central Repository consistent with Article VI, Section 6.1(m). The Comprehensive Information S[s]ecurity P[p]lan must be updated annually. The Comprehensive Information S[s]ecurity P[p]lan must include an overview of the Plan Processor's network security controls, processes and procedures pertaining to the CAT Systems. Details of the Comprehensive Information S[s]ecurity P[p]lan must document how the Plan Processor will protect, monitor and patch the environment; assess it for vulnerabilities as part of a managed process, as well as the process for response to security incidents and reporting of such incidents. The Comprehensive Information S[s]ecurity P[p]lan must address physical security controls for corporate, data center, and leased facilities where Central Repository data is transmitted or stored. The Plan Processor must have documented "hardening baselines" for systems that will store, process, or transmit CAT Data or [PII] Customer and Account Attributes data.

4.1.1 Connectivity and Data Transfer

[The CAT System(s) must have encrypted internet connectivity. CAT Reporters] Industry members must connect to the CAT infrastructure using secure methods such as private lines for machine-to machine interfaces or [(for smaller broker-dealers)] encrypted Virtual Private Network connections over public lines for manual web-based submissions. Participants must connect to the CAT infrastructure using private lines. For all connections to CAT infrastructure, the Plan Processor must implement capabilities to allow access (i.e., "allow list") only to those countries where CAT reporting or regulatory use is both necessary and expected. Where possible, more granular "allow listing" should be implemented (e.g., by IP address). The Plan Processor must establish policies and procedures to allow access if the location cannot be determined technologically.

* * * * *

4.1.2 Data Encryption

All CAT Data must be encrypted at rest and in flight using industry standard best practices (e.g., SSL/TLS) including archival data storage methods such as tape backup. Symmetric key encryption must use a minimum key size of 128 bits or greater (e.g., AES-128), larger keys are preferable. Asymmetric key encryption (e.g., PGP) for exchanging data between Data Submitters and the Central Repository is desirable.

Storage of unencrypted [PII] Customer and Account Attributes data is not permissible. [PII] Customer and Account Attributes encryption methodology must include a secure documented key management strategy such as the use of HSM(s). The Plan Processor must

describe how [PII] Customer and Account Attributes encryption is performed and the key management strategy (e.g., AES-256, 3DES).

* * * * *

4.1.3. Data Storage and Environment

Data centers housing CAT Systems (whether public or private) must, at a minimum, be AICPA SOC 2 certified by a qualified third-party auditor that is not an affiliate of any of the Participants or the CAT Processor, and be physically located in the United States. The frequency of the audit must be at least once per year.

* * * * *

4.1.4 Data Access

The Plan Processor must provide an overview of how access to [PII] Customer and Account Attributes and other CAT Data by Plan Processor employees and administrators is restricted. This overview must include items such as, but not limited to, how the Plan Processor will manage access to the systems, internal segmentation, multi-factor authentication, separation of duties, entitlement management, background checks, etc.

The Plan Processor must develop and maintain policies and procedures reasonably designed to prevent, detect, and mitigate the impact of unauthorized access or usage of data in the Central Repository. Such policies and procedures must be approved by the Operating Committee, and should include, at a minimum:

- Information barriers governing access to and usage of data in the Central Repository;
- Monitoring processes to detect unauthorized access to or usage of data in the Central Repository; and
- Escalation procedures in the event that unauthorized access to or usage of data is detected.

A Role Based Access Control ("RBAC") model must be used to permission users with access to different areas of the CAT System. The CAT System must support [an arbitrary number of]as many roles as required by Participants and the Commission to permit [with]access to different types of CAT Data, down to the attribute level. The administration and management of roles must be documented. Periodic reports detailing the current list of authorized users and the date of their most recent access must be provided to Participants, the SEC and the Operating Committee. The reports provided to[of] the Participants and the SEC will include only their respective list of users. The Participants must provide a response to the report confirming that the list of users is accurate. The required frequency of this report will be defined by the Operating Committee. The Plan Processor must log every instance of access to Central Repository data by users.